

GUÍA METODOLÓGICA DETALLADA PARA APLICAR Y ANALIZAR LA ENCUESTA

de Ciberseguridad y Gobernanza IA

Versión: 1.0

Fecha: Enero 2026

Autores: Consorcio de Científicos de Datos, Estrategas de Ciberseguridad y Especialistas en Resiliencia Digital

I. FASE DE PREPARACIÓN (Semana -1 a 0)

1.1 Definición de Objetivos y Scope

Paso 1: Clarificar Propósito

- ¿Qué motivación impulsó esta evaluación? (compliance, mejora interna, benchmarking, due diligence)
- ¿Qué decisiones esperan tomar con los resultados?
- ¿A qué audiencia reportarán? (Board, C-suite, gestión, equipo técnico)

Paso 2: Definir Scope Organizacional

- ¿Toda la organización o unidades específicas? (p.ej., solamente IT, solamente Finance, todas)
- ¿Qué sistemas IA están in-scope? (core business systems, back-office, pilots)
- ¿Qué jurisdicciones? (España, UE-wide, global)

Paso 3: Establecer Contexto Normativo

- Normativa vigente en scope: EU AI Act, NIS2, GDPR, LOPD, ISO 27001, NIST CSF 2.0
- Calendarios críticos (p.ej., "NIS2 compliance deadline enero 2025", "EU AI Act Art. 50 agosto 2026")
- Marcos de referencia seleccionados (NIST AI RMF 1.0, ISO 23894)

1.2 Selección y Composición del Equipo Evaluador

Composición Recomendada (7-10 personas):

- **1 Líder Evaluación:** CISO o Chief Risk Officer (sponsor, decisiones)
- **2 Especialistas NIST/Ciberseguridad:** Expertise técnico en frameworks
- **1 Especialista en IA/Data:** Perspectiva de gobernanza IA, fairness, bias
- **1 Compliance Officer:** Normativa, calendarios, sanciones
- **1 Líder de Negocio:** Contexto estratégico, tolerancia de riesgo
- **1 Representante IT Operaciones:** Realidades de implementación
- **1 Comunicador/Facilitador:** Notas, síntesis, presentación

Capacitación del Equipo (4 horas):

- Briefing en NIST AI RMF 1.0 (estructura, funciones, características)
- Revisión guía encuesta (preguntas, escalas, criterios)
- Calibración de evaluadores (ejercicio de scoring en 3-5 preguntas conjuntas para alinear criterios)

1.3 Logística y Comunicación

Preparación de Respondentes:

- Email a stakeholders claves: "En próximas 2-3 semanas evaluaremos madurez ciberseguridad. Preparar: políticas, métricas, incident logs, training records"
- Calendario de entrevistas (1h por módulo, 3-4 sesiones/equipo)
- Acceso a documentación: share de carpeta con políticas, runbooks, dashboards

Planificación de Entrevistas:

- Semana 1: Gobernanza + Mapeo (Módulos 1-2)
- Semana 2: Medición + Vulnerabilidades (Módulos 3-4)
- Semana 3: SIEM + Capacitación (Módulo 5)

Comunicación Inicial:

- Mensaje del líder: "Evaluación no es auditoría punitiva; es roadmap hacia madurez"
- Confidencialidad garantizada: "Datos agregados, no culpabilidad"
- Beneficios: "Entenderemos gaps, priorizaremos inversión, conectaremos con peers"

II. FASE DE EJECUCIÓN (Semanas 1-3)

2.1 Estructura de Sesiones de Entrevista

Duración por Sesión: 60-90 minutos

Formato: Video-conferencia o presencial (preferentemente presencial para calibración en tiempo real)

Participantes: 2-3 evaluadores + 4-6 respondentes (IT, Gobernanza, Negocio, Compliance)

Documentación: 1 evaluador toma notas, 1 facilita preguntas

Agenda Típica de Sesión:

00:00-05:00	Bienvenida, contexto, confidencialidad
05:00-10:00	Módulo intro (contexto negocio, drivers de ciberseguridad)
10:00-50:00	Preguntas Módulo (10-15 preguntas, ~3-4 min por pregunta)
50:00-80:00	Profundización/follow-ups (si respuestas vagas, pedir evidencia)
80:00-90:00	Síntesis, next steps

2.2 Técnicas de Entrevista y Profundización

Regla de Oro: "¿Dónde está la evidencia?"

Para cada pregunta, el evaluador debe obtener:

1. **Respuesta directa** (Nivel 1-5)
2. **Evidencia concreta** (documento, log, métrica, captura de pantalla)
3. **Frequency/Cadencia** (¿cada cuándo ocurre?)
4. **Owner/Accountability** (¿quién es responsable?)
5. **Gaps conocidos** (¿qué falta?)

Ejemplo de Profundización:

- **Pregunta:** "¿Miden accuracy y bias del modelo de credit scoring?"

- **Respuesta Inicial:** "Sí, lo hacemos"
- **Follow-up:** "¿Puedo ver el reporte más reciente de accuracy?"
- **Respuesta:** "No tenemos reporte formal, pero nuestro data scientist lo chequea"
- **Evaluación:** Nivel 2 (informal, no documentado)
- **Notas:** "Falta: reporte estándar, frequency, ownership, trending"

Preguntas de Sondeo Útiles:

- "¿Cómo lo saben?" (validar conocimiento vs. suposición)
- "¿Desde cuándo se hace así?" (madurez temporal)
- "¿Quién lo verifica?" (independencia)
- "¿Qué pasó la última vez que falló?" (respuesta ante incidente)
- "¿Cómo lo miden?" (cuantificación)
- "¿Quién tiene la responsabilidad?" (ownership)

2.3 Calibración Inter-Evaluadores

Sesión de Calibración (post Módulo 1, 30 min):

- Todos evaluadores comparten scoring de primeras preguntas
- Discuten discrepancias (p.ej., un evaluador dice Nivel 3, otro Nivel 4)
- Llegan a consenso usando evidencia (documento, métrica)
- Ajustan "anchor points" para siguiente módulo

Ejemplo de Calibración:

- **Pregunta 1.1.1** (Política IA formalmente aprobada)
- **Evaluador A:** Nivel 4 ("Tienen política, revisiones trimestrales")
- **Evaluador B:** Nivel 3 ("Política existe, pero Board nunca la aprobó formalmente")
- **Resolución:** Consenso Nivel 3 (documentación sola ≠ aprobación ejecutiva)
- **Actualización criterio:** "Nivel 4 requiere Board sign-off + revisión trimestral evidenciado"

III. FASE DE ANÁLISIS Y SÍNTESIS (Semana 4)

3.1 Entrada de Datos en Plantilla de Scoring

Plantilla Recomendada (spreadsheet o herramienta especializada como ServiceNow, Archer, Isora):

Pregunta	Módulo	Nivel Asignado (1-5)	Evidencia	Owner	Gaps Identificados	Comentarios
1.1.1	GOVERN	3	Policy doc dated 2025-03-15	CISO	"No tenemos aprobación Board formal"	Regular updates, but not exec approved
1.1.2	GOVERN	2	Verbal tolerance, not documented	CRO	"Necesitamos escalas RAG formales"	Informal, case-by-case

Validaciones Automáticas:

- Verificar rango 1-5 (no valores fuera de rango)
- Campos "Evidencia" no vacíos (validar rigor)
- Timestamps para auditabilidad

3.2 Cálculo de Puntuación por Módulo

Fórmula Base:

Puntuación Módulo = (Suma de Niveles en Módulo) / (Número de Preguntas en Módulo)

Ejemplo Módulo 1 (Gobernanza y Riesgo):

- Pregunta 1.1.1: Nivel 3
- Pregunta 1.1.2: Nivel 2
- Pregunta 1.1.3: Nivel 4
- Pregunta 1.1.4: Nivel 3
- Pregunta 1.2.1: Nivel 2
- Pregunta 1.2.2: Nivel 3
- Pregunta 1.2.3: Nivel 2
- Pregunta 1.2.4: Nivel 3
- Pregunta 1.3.1: Nivel 1
- Pregunta 1.3.2: Nivel 2

Cálculo: $(3+2+4+3+2+3+2+3+1+2) / 10 = 2.5$ → **Nivel 2.5 (Incipiente)**

3.3 Cálculo de Puntuación Global

Fórmula:

Madurez Global = (Score Módulo 1 + Score Módulo 2 + ... + Score Módulo 5) / 5

Ponderación Opcional (si algunos módulos son críticos para organización):

Madurez Global = $(Peso1 \times Score1 + Peso2 \times Score2 + \dots + Peso5 \times Score5) / \text{Suma Pesos}$

Ejemplo de Ponderación (organización financiera, riesgo alto):

- Gobernanza: 25% (crítico para compliance)
- Mapeo: 15%
- Medición: 25% (métricas de riesgo críticas)
- Vulnerabilidades: 20%
- SIEM/Capacitación: 15%

Cálculo: $2.5 \times 0.25 + 3.0 \times 0.15 + 2.0 \times 0.25 + 3.5 \times 0.20 + 2.5 \times 0.15 = 2.75$ (Definido, tendiendo a Cuantificado)

3.4 Análisis de Gaps por Módulo

Para cada Módulo:

1. Identificar preguntas con scoring más bajo (<2.5)
2. Listar gaps explícitos (p.ej., "Falta RACI formal", "No tenemos SLA pentesting")
3. Evaluar criticidad de gap (¿bloquea compliance? ¿aumenta riesgo significativamente?)
4. Estimar esfuerzo remediation (bajo <50h, medio 50-200h, alto >200h)

Matriz de Priorización Gap:

	Criticidad ALTA	Criticidad MEDIA	Criticidad BAJA
Esfuerzo BAJO	▲ Prioridad 1 (quick wins)	▲ Prioridad 2 (medium term)	→ Prioridad 3 (nice to have)
Esfuerzo MEDIO	▲ Prioridad 1 (strategic)	▲ Prioridad 2 (roadmap)	→ Prioridad 4 (future)
Esfuerzo ALTO	▲ Prioridad 2 (multi-phase)	▲ Prioridad 3 (future)	→ Backlog (defer)

Ejemplo Gap Analysis (Módulo 3 - Medición):

| Gap | Criticidad | Esfuerzo | Prioridad | Propuesta Remedación |

|----|-----|-----|-----|-----|

| No miden accuracy de modelos | ALTA | BAJO | 1 | Implementar Model Card template, quarterly assessment |

| Falta bias audit para hiring system | ALTA | MEDIO | 1 | Contratar firma especializada, implementar fairness metrics |

| SIEM sin ML/anomaly detection | MEDIA | ALTO | 2 | Upgrade SIEM Q2 2026, phase out false positives |

IV. FASE DE REPORTERÍA Y ACCIÓN (Semana 5-6)

4.1 Estructura del Reporte Ejecutivo

Audiencia: Board, C-suite, Inversores

Duración: 20-30 min presentación + 10 min Q&A

Formato: Slides + Executive Summary (2 pages)

Contenido Recomendado:

Portada

- Título: "Evaluación de Madurez Ciberseguridad y Gobernanza IA - [Organización] - Enero 2026"
- Clasificación: CONFIDENCIAL
- Evaluadores + Fecha

Slide 1: Contexto y Alcance

- Propósito: "Entender posición actual, identificar roadmap"
- Scope: "Toda organización, 47 preguntas, 6 módulos"
- Metodología: "NIST AI RMF 1.0 + ISO 27001 + best practices"
- Métricas: "5-level maturity scale (1=Ad-hoc, 5=Optimized)"

Slide 2: Puntuación Global

MADUREZ GLOBAL: 2.75 / 5.0
INTERPRETACIÓN: INCIPIENTE→DEFINIDO

Breakeven: Definido (3.0) required
Brecha: -0.25 (acciones próximas)

Slide 3: Scorecard por Módulo

Gobernanza & Riesgo:	2.5		INCIPIENTE
Mapeo Contexto:	3.0		DEFINIDO
Medición & Métricas:	2.0		INCIPIENTE
Vulnerabilidades/Pentesting:	3.5		DEFINIDO+
SIEM & Capacitación:	2.5		INCIPIENTE
PROMEDIO:	2.75		INCIPIENTE→DEFINIDO

Slide 4: Top 5 Fortalezas

1. Pentesting anual documentado (vulnerabilidades Nivel 3.5)
2. SIEM básico con 20+ fuentes de logs
3. Políticas de ciberseguridad formales (aunque sin aprobación Board)
4. Capacitación SAT anual para IT y roles críticos (>70% cobertura)
5. Risk committee trimestral (aunque sin métricas KPI)

Slide 5: Top 5 Oportunidades de Mejora

6. Falta RACI formal para gobernanza IA (Nivel 2 → Nivel 3) — Prioridad 1, Esfuerzo BAJO
7. Acción: Documentar roles (Owner, Accountable, Consulted, Informed) para 10 decisiones críticas IA
8. Plazo: Febrero 2026 (2 semanas)
9.
Dueño: CISO + AI Governance Lead
10.
No miden bias en modelos críticos (Nivel 1 → Nivel 3) — Prioridad 1, Esfuerzo MEDIO
11. Acción: Implementar fairness audit para hiring + credit models; target <5% demographic parity gap
12. Plazo: Marzo 2026 (4 semanas)
13.
Dueño: Chief Data Officer + Ethics Officer
14.
SIEM sin ML/anomaly detection (Nivel 3 → Nivel 4) — Prioridad 2, Esfuerzo ALTO
15. Acción: Evaluar SIEM avanzado; pilot con ML models para threat detection
16. Plazo: Q2 2026 (enterprise purchase), Q3 implementation
17. Dueño: Chief Security Officer
18.
Inversión: ~€200K (COGS + services)
19.
Pentesting NO incluye ataques IA-específicos (Nivel 2 → Nivel 4) — Prioridad 1, Esfuerzo MEDIO
20. Acción: Contratar especialista pentesting IA; incluir data poisoning, prompt injection, model extraction
21. Plazo: Marzo-abril 2026
22. Dueño: Chief Architect + Security Lead
23.
Inversión: ~€50K (external firm)
24.
Falta ML-BOM para gestión supply chain IA (Nivel 1 → Nivel 3) — Prioridad 2, Esfuerzo MEDIO
25. Acción: Catalogar modelos pre-entrenados, dependencies, provenance
26. Plazo: April 2026
27. Dueño: Chief Architect
28. Tooling: Implement RL Spectra Assure o similar (~€30K)

Dueño: CISO + AI Governance Lead

No miden bias en modelos críticos (Nivel 1 → Nivel 3) — **Prioridad 1, Esfuerzo MEDIO**

Dueño: Chief Data Officer + Ethics Officer

SIEM sin ML/anomaly detection (Nivel 3 → Nivel 4) — **Prioridad 2, Esfuerzo ALTO**

Inversión: ~€200K (COGS + services)

Pentesting NO incluye ataques IA-específicos (Nivel 2 → Nivel 4) — **Prioridad 1, Esfuerzo MEDIO**

Inversión: ~€50K (external firm)

Falta ML-BOM para gestión supply chain IA (Nivel 1 → Nivel 3) — **Prioridad 2, Esfuerzo MEDIO**

Slide 6: Roadmap de Implementación (18 meses)

Q1 2026 (Ene-Mar)

- RACI governance formalization [2 semanas]
- Bias audit pilots (hiring, credit) [4 semanas]
- IA-specific pentesting planning [ongoing]

Q2 2026 (Abr-Jun)

- SIEM evaluation & procurement
- ML-BOM platform implementation
- IA pentesting round 1 execution

Q3 2026 (Jul-Sep)

- SIEM deployment & team training
- EU AI Act Art. 50 implementation (Aug 2026 deadline)
- Re-assessment survey (post-interventions)
- Continue IA pentesting

Q4 2026 (Oct-Dic)

- SIEM optimization (reduce alert fatigue)
- Board review: Updated maturity scorecard
- Plan 2027 roadmap

2027 H1: Scaling interventions, Target Madurez 3.5-4.0

Slide 7: Estimación de Inversión

Prioridad 1 (Quick wins + Strategic): €280K total

- RACI + Governance formalization: €20K (consulting)
- Bias audit platform + training: €80K (tools + external audit)
- IA-specific pentesting: €50K (external firm)

Prioridad 2 (Roadmap): €250K + €200K capex

- SIEM upgrade: €200K capex + €30K/year services
- ML-BOM platform: €30K (tools) + €20K (implementation)
- Additional training & resources: €70K/year

Slide 8: Riesgos si No Se Actúa

Risk of Inaction

- EU AI Act Compliance: €35M+ sanciones (Q2 2026)
- Data Breach (undetected por falta SIEM ML): €5-10M+ incident cost
- Regulatory Audit Findings: €2-5M remediation cost
- Reputational Damage: Incalculable
- Talent Loss: Security-conscious employees leave

Slide 9: Next Steps & Governance

- Aprobación: Board aprueba roadmap + presupuesto (esta semana)
- Sponsorship: CFO + CISO designados co-sponsors
- Cadencia de Revisión: Monthly steering committee (Exec + Leads), quarterly Board update
- Re-assessment: December 2026 (9 meses post-assessment)

4.2 Reporte Detallado para Equipos Técnicos

Audiencia: Equipos técnicos, gestores de proyecto, implementadores

Duración: 1-2 horas (taller colaborativo)

Documentos: Matriz de gaps + playbooks de remediación

Contenido:

Parte 1: Revisión Gap Detallado por Módulo

- Pregunta → Score actual → Score target → Gap
- Evidencia de brecha (documento faltante, métrica inexistente)
- Propuesta remediación específica
- Recursos necesarios, timeline, owner

Parte 2: Playbook de Implementación

GAP: "Falta RACI formal para gobernanza IA"

Objetivo: Documentar RACI para 10 decisiones críticas IA por febrero 2026

Scope: IT + Negocio + Compliance

Owner: CISO (lead), AI Governance Lead (co-lead)

Hitos:

Week 1: Listar 10 decisiones críticas (Board workshop)

Week 2: Definir RACI para cada decisión (Responsible, Accountable, Consulted, Informed)

Week 3: Documentar en wiki/intranet, capacitar stakeholders

Week 4: Validación + governance live

Success Criteria:

- Document completeness: 100%
- Stakeholder understanding: >80% (survey)
- RACI applied to decisions: 100% of critical IA decisions use RACI

Risk & Mitigation:

- Risk: Stakeholder alignment delays → Mitigación: Pre-align with C-level
- Risk: RACI becomes "shelf-ware" → Mitigación: Monthly audit of RACI adherence

V. FASE DE SEGUIMIENTO (Posturas Periódicas)

5.1 Cadencia de Re-assessment

Recomendación:

- **Primer Re-assessment:** 6-9 meses post-assessment inicial (octubre 2026)
- **Frecuencia:** Anual thereafter (enero 2027, enero 2028, etc.)
- **Lightweight Review:** Semestral (abril/mayo) para KPIs clave (no re-survey completo)

Metodología Re-assessment:

- Usar mismos evaluadores si es posible (continuidad, calibración)
- Validar evidencia de remediaciones (p.ej., "¿RACI implemented as planned?")
- Score solo preguntas donde target acción ejecutada
- Trending analysis (direccional: mejoró? se estancó? empeoró?)

5.2 Dashboards de Tracking

Dashboard Ejecutivo (actualizado mensualmente):

CIBERSEGURIDAD & IA GOVERNANCE MATURITY TRACKER			
Baseline (Jan 2026):	2.75	/ 5.0	
Target (Oct 2026):	3.25	/ 5.0	
Actual Progress (Feb 2026):	2.80	/ 5.0	(+0.05)
Modules Tracking:			
1. Governance:	2.5 → 3.0		(target: 3.0)
2. Map:	3.0 → 3.0		(on track)
3. Measure:	2.0 → 2.7		(progressing)
4. Vulnerabilities:	3.5 → 3.5		(on track)
5. SIEM/Training:	2.5 → 2.6		(slow progress)
Top Risks (Yellow/Red):			
⚠	SIEM ML upgrade delayed (Q2 → Q3)		
⚠	Bias audit scope reduced due to vendor lead times		
✓	RACI documented & operationalized (Feb target met)		
Spending Tracking:			
Budget Allocated: €280K (Prioridad 1)			
Spent to Date: €65K (23%)			
Burn Rate: On track for completion by June			

Dashboard Técnico (actualizado quincenalmente):

- KPI por área: Pentesting findings trend, SIEM alert volume, training completion rate
- Incident response metrics: MTTD, MTTR vs. SLA
- Compliance checklist: EU AI Act readiness, NIS2 audit prep

VI. BEST PRACTICES Y PITFALLS COMUNES

6.1 Best Practices

- 29. Honestidad sobre brecha: Organizaciones que reconocen niveles bajos actúan más rápido que aquellas que sobreestiman
- 30. Evidencia concreta: Documentos > percepciones; logs > anécdotas
- 31. Ownership claro: Cada gap + remediación con dueño designado; no "comité"
- 32. Iteración ágil: Mejor hacer pequeñas mejoras frecuentes que esperar "programa perfecto"
- 33. Comunicación proactiva: Share resultados con all-hands; transparencia builds trust

6.2 Pitfalls Comunes a Evitar

- 34. "Assessment Shelf-ware": Reportes bonitos que nadie lee ni actúa
- 35.

Mitigación: Monthly steering meetings, public dashboard, executive accountability

36.

Moving Goalposts: "Redefinimos Nivel 3 para vernos mejor"

37.

Mitigación: Criteria locked post-calibration; external validation

38.

Underestimating Effort: "Implementaremos RACI en 2 semanas"

39.

Mitigación: Estimate conservador + 20% buffer; track actuals

40.

Siloed Improvements: IT mejora SIEM, pero negocio no lo usa

41.

Mitigación: Cross-functional steering; feedback loops

42.

Compliance Theater: "Cumplimos EU AI Act porque llenamos formulario"

43. Mitigación: Spirit + letter; actual controls implemented, not just check boxes

Mitigación: Monthly steering meetings, public dashboard, executive accountability

Moving Goalposts: "Redefinimos Nivel 3 para vernos mejor"

Mitigación: Criteria locked post-calibration; external validation

Underestimating Effort: "Implementaremos RACI en 2 semanas"

Mitigación: Estimate conservador + 20% buffer; track actuales

Siloed Improvements: IT mejora SIEM, pero negocio no lo usa

Mitigación: Cross-functional steering; feedback loops

Compliance Theater: "Cumplimos EU AI Act porque llenamos formulario"

VII. RECURSOS Y HERRAMIENTAS RECOMENDADAS

Herramientas de Assessment

Herramienta	Mejor Para	Costo
Spreadsheet (Excel/GSheets)	Pequeño (<100 respuestas)	Free
Archer (CA)	Enterprise, audit-ready	€50K+ /año
ServiceNow GRC	Integración con IT ops	€30K-50K+ /año
Isora GRC	CSF + IA RMF specialized	€25K+ /año
Vanta/Drata	Compliance-focused	€10K-20K/año

Frameworks y Documentación de Referencia

- NIST AI 100-1 (AI RMF 1.0): <https://nvlpubs.nist.gov/nistpubs/ai/nist.ai.100-1.pdf>
- NIST CSF 2.0: <https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf>
- NIST GenAI Profile (AI 600-1): [NIST website]
- ISO/IEC 23894 (AI Risk Management)
- EU AI Act (RIA 2024/1689): <https://artificialintelligenceact.eu/es/>
- OWASP LLM Top 10: <https://genai.owasp.org/llm-top-10/>
- MITRE ATT&CK: <https://attack.mitre.org/>

Consultorías Especializadas

- Deloitte, EY, PWC (Big 4): Full assessment + roadmap (~€200K-500K)
- Nozomi Networks, CrowdStrike (security focused): Pentesting + SIEM (~€50K-150K)
- Boehringer Ingelheim, Riskified (IA governance specific): Bias audit + fairness (~€50K-100K)

Fin de Guía Metodológica

Documento de Implementación y Análisis

Enero 2026 | Confidencial